BÀI TẬP TÌNH HUỐNG HUỐNG 7 (TUẦN 33)
MÔN AN TOÀN VÀ BẢO MẬT HỆ THỐNG THÔNG TIN
HỆ MẬT MÃ KHÓA CÔNG KHAI (BẤT ĐỐI XỨNG)

Họ và tên: Cao Thị Thanh Ngân
MSV: 4651050167
Nhóm 2

Bài làm:

Bài 1: Cho p = 7, q = 19 và e = 5. Chuỗi ký tự "TIN HOC"

Yêu cầu:

1. Tìm khóa bí mật d

2. Mã hóa chuỗi ký tự trên

3. Giải mã lại

1. Tạo khóa RSA:
n = p*q = 7*19 = 133
Khi đó , ϕ(n) = (p-1)*(q-1) = 108
Chọn giá trị e = 5, vì 1 <e < 108 và UCLN(e, 108) = 1
Theo giải thuật Euclide mở rộng tìm d: e*d mod ϕ(n) = 1
=> Đưa bài toán về dạng e*d + ϕ(n)*k = 1
⇔ e*d = ϕ(n)*k + 1
⇔ e*d - ϕ(n)*k = 1
Đặt y = -k, x = d: ⇒ e*x + ϕ(n)*y = 1
⇔ 5*x + 108*y = 1
Ta có bảng sau:

i	$r_i = r_{i-2} \bmod r_{i-1}$	$q_i = \lvert r_{i-2} / r_{i-1} \rvert$	$x_i = x_{i-2} - q_i * x_{i-1}$	$y_i = y_{i-2} - q_i * y_{i-1}$
-1	108		0	1
0	5		1	0
1	3	21	-21	1
2	2	1	22	-1
3	1	1	-43	2

$\Rightarrow x = 5^{-1} \bmod 108 = -43 + 108 = 65$
$\Rightarrow d = 65$
Ta được: Khóa công khai (108, 5). Khóa bí mật (7, 19, 65)

2. Lập mã:

Bản rõ	Mã đối chiếu	Bản mã (x^e mod n)
T	19	38
I	8	50
N	13	90
(space)	16	4
H	7	49
O	14	105
C	2	32

3. Giải mã

Bản mã	Mã đối chiếu của Bản rõ (y^d mod n)	Bản rõ
38	19	T
50	8	I
90	13	N
87	26	(space)
49	7	H
105	14	O
32	2	C

Bài 2: Cho p = 11, q = 23. Tự chọn e, với 1 < e < (n), sao cho UCLN(e,(n)) = 1.

Chuỗi ký tự "KY THUAT PHAN MEM"

Yêu cầu:

1. Tìm khóa bí mật d

2. Mã hóa chuỗi ký tự trên

3. Giải mã lại

1. Tạo khóa RSA:

n = p*q = 11*23 = 253

Khi đó , ϕ(n) = (p-1)*(q-1) = 220

Chọn giá trị e = 7, vì 1 <e < 220 và UCLN(7, 220) = 1

Theo giải thuật Euclide mở rộng tìm d: e*d mod ϕ(n) = 1

=> Đưa bài toán về dạng e*d + ϕ(n)*k = 1

⇔ e*d = ϕ(n)*k + 1

⇔ e*d - ϕ(n)*k = 1

Đặt y = -k, x = d: ⇒ e*x + ϕ(n)*y = 1

⇔ 7*x + 220*y = 1

Ta có bảng sau

i	r_i	q_i	x_i	y_i
-1	220		0	1
0	7		1	0
1	3	31	-31	1
2	1	2	63	5

⇒ x = 7^{-1} mod 220 = 63

⇒ d = 63

Ta được: Khóa công khai (253, 7). Khóa bí mật (11, 23, 63)

2. Lập mã:

Bản rõ	Mã đối chiếu	Bản mã (x^e mod n)
K	10	117
Y	24	47
(space)	26	87
T	19	38
H	7	49
U	20	20
A	0	0
T	19	38
(space)	26	87
P	15	78
H	7	49

A	0	0
N	13	90
(space)	26	87
M	12	122
E	4	93
M	12	122

3. Giải mã:

Bản mã	Mã đối chiếu của Bản rõ (y^d mod n)	Bản rõ
117	10	K
47	24	Y
87	26	(space)
38	19	T
49	7	H
20	20	U
0	0	A
38	19	T
87	26	(space)
78	15	P
49	7	H
0	0	A
90	13	N
87	26	(space)
122	12	M
93	4	E
122	12	M

BÀI TẬP TÌNH HUỐNG

Bài 1 – Lựa chọn triển khai RSA trong hệ thống thực tế

Một hệ thống thương mại điện tử cần:

• Bảo vệ thông tin thanh toán của khách hàng

• Truyền dữ liệu qua Internet

• Xác thực server với client

Nhóm phát triển đề xuất: Dùng RSA để mã hóa toàn bộ dữ liệu truyền đi

Yêu cầu

1. Phân tích và đánh giá để làm rõ tính hợp lý của đề xuất trên.

2. Phân tích làm rõ hạn chế của hệ mật mã RSA trong trường hợp này.

3. Đề xuất giải pháp tối ưu, và giải thích rõ tính tối ưu của giải pháp đã đề xuất.

1. *Phân tích và đánh giá tính hợp lý của đề xuất*

Hệ mật mã RSA (hệ mật mã khóa công khai | bất đối xứng), nghĩa là sử dụng một cặp khóa: khóa công khai để mã hóa và khóa bí mật để giải mã. Loại mật mã này phù hợp cho các công việc như:

- Xác thực danh tính giữa máy chủ và máy khách.

- Trao đổi khóa phiên dùng tạm thời.

- Mã hóa các thông tin nhỏ như mật khẩu hoặc khóa mã hóa khác.

Tuy nhiên, việc dùng RSA để mã hóa toàn bộ dữ liệu truyền đi trong một hệ thống thương mại điện tử (thông tin khách hàng, hình ảnh, danh mục sản phẩm, đơn hàng, thông tin giao dịch, …) là không hợp lý và không khả thi vì:

- Tốc độ xử lý chậm: Tốc độ mã hóa và giải mã của RSA rất chậm so với nhu cầu thực tế của hệ thống thương mại điện tử. Khi có hàng nghìn khách hàng truy cập cùng lúc, hệ thống sẽ bị quá tải, thời gian phản hồi lâu, dẫn đến trải nghiệm người dùng kém và có thể mất khách hàng.

- Dữ liệu thanh toán không cần phải mã hóa hoàn toàn bằng RSA; chỉ cần bảo vệ bí mật và xác thực nguồn gốc là đủ.

- Đề xuất này không cân nhắc đến hiệu năng thực tế của hệ thống khi vận hành trên mạng Internet với lưu lượng lớn.

Tóm lại, đề xuất chỉ tập trung vào độ bảo mật mà bỏ qua yếu tố tốc độ và khả năng mở rộng, nên không phù hợp với yêu cầu thực tế của một hệ thống thương mại điện tử.

***2.** Phân tích hạn chế của hệ mật mã RSA trong trường hợp này*

Hệ mật mã RSA có những hạn chế rõ rệt khi áp dụng để mã hóa toàn bộ dữ liệu truyền đi trong hệ thống thương mại điện tử:

- Tốc độ xử lý chậm: Nguyên nhân là do RSA dựa trên các phép toán lũy thừa với số nguyên cực lớn theo công thức:

$$y = x^e \bmod n : \text{mã hóa}$$

$$x = y^d \bmod n : \text{giải mã}$$

(x: bản rõ, y: bản mã, e: số mũ công khai, d: số mũ bí mật, n=p*q: số modun với p, q là số nguyên tố lớn)

Mỗi lần mã hóa chỉ xử lý được một lượng dữ liệu rất nhỏ (vài trăm byte). Nếu dữ liệu thanh toán dài, hệ thống phải chia nhỏ và mã hóa nhiều lần, dẫn đến thời gian chậm gấp nhiều lần so với các phương pháp khác. Trong khi đó, một hệ thống thương mại điện tử cần xử lý hàng triệu giao dịch mỗi ngày.

- Vì thực hiện tính toán với số rất lớn nên tốc độ thấp → mật mã khóa công khai "chỉ phù hợp với lượng nhỏ dữ liệu"

- Không hỗ trợ bảo mật chuyển tiếp hoàn hảo: Nếu khóa bí mật của máy chủ bị lộ sau này (do hack server, nhân viên nội bộ, hoặc lỗi quản lý), thì toàn bộ dữ liệu thanh toán đã truyền trước đó đều có thể bị giải mã. Điều này rất nguy hiểm cho thông tin thanh toán nhạy cảm. Vì: Dữ liệu được mã hóa bằng khóa công khai → chỉ giải mã được bằng khóa bí mật.

Công thức: C=E(Kp,M) và M=D(Ks,C)

Khóa công khai (Kp) và khóa bí mật (Ks) là cặp cố định. Không có cơ chế thay đổi khóa cho từng phiên.

Do đó, một khi khóa công khai bị lộ, hacker chỉ cần lấy lại toàn bộ bản mã C cũ (có thể lưu trên mạng) rồi áp dụng M=D(Ks,C) là ra ngay bản rõ M.

- Quản lý khóa phức tạp và dễ bị tấn công: Máy chủ phải bảo vệ khóa bí mật tuyệt đối. Máy khách phải nhận đúng khóa công khai của máy chủ thật. Nếu không có cơ chế kiểm tra, khóa công khai dễ bị thay thế. Khóa công khai có thể chia sẻ, nhưng phải được xác thực. Và đây là hạn chế cố hữu của RSA: không tự động đảm bảo tính xác thực nguồn gốc của khóa công khai.

- Không giải quyết triệt để việc xác thực hai chiều: RSA chỉ giúp xác thực một chiều nếu không kết hợp với các công cụ khác. Khi client dùng khóa công khai của server để mã hóa, client có thể tin rằng chỉ server mới giải mã được (vì chỉ server có khóa bí mật). Đây là xác thực server. Nhưng server không có cách nào biết chắc client là ai thật.

Những hạn chế này cho thấy RSA không phải là lựa chọn tối ưu khi dùng để mã hóa dữ liệu lớn và liên tục qua mạng Internet.

***3.** Đề xuất giải pháp tối ưu và giải thích tính tối ưu*

* Giải pháp tối ưu: Sử dụng kết hợp mật mã khóa công khai RSA và mật mã khóa bí mật đối xứng.

Cụ thể:

- Giai đoạn 1 - Thiết lập và trao đổi khóa: Máy khách và máy chủ sử dụng mật mã khóa công khai RSA để trao đổi an toàn một khóa bí mật ngẫu nhiên.

+ Máy chủ gửi khóa công khai của mình cho máy khách.

+ Máy khách sinh ra một khóa bí mật ngẫu nhiên (gọi là khóa phiên), sau đó mã hóa khóa phiên này bằng khóa công khai RSA của máy chủ theo công thức: C=E(Kp,Kphiên) rồi gửi bản mã C về máy chủ.

+ Máy chủ dùng khóa bí mật RSA của mình để giải mã và lấy được khóa phiên: Kphiên=D(Ks,C)

+ Đồng thời, máy chủ sử dụng chữ ký số RSA để ký số lên thông điệp, giúp máy khách kiểm tra và xác thực rằng máy chủ là thật.

- Giai đoạn 2 - Truyền dữ liệu thực tế: Sau khi cả hai bên đã có chung khóa phiên, toàn bộ thông tin thanh toán, số thẻ, địa chỉ, hóa đơn… đều được mã hóa bằng mật mã khóa bí mật đối xứng với tốc độ cao.

Công thức: C=E(Kphiên,M), M=D(Kphiên,C)

* Giải thích tính tối ưu của giải pháp này:

- Tốc độ cao và phù hợp với lượng dữ liệu lớn: Mật mã khóa bí mật đối xứng thực hiện các phép toán trên bit và byte nên tốc độ rất cao, có thể xử lý lượng lớn dữ liệu. Ngược lại, RSA chỉ được dùng cho lượng dữ liệu rất nhỏ (chỉ khóa phiên vài trăm byte). Điều này khắc phục hoàn toàn hạn chế "tốc độ thấp" của RSA khi mã hóa toàn bộ dữ liệu.

- An toàn cao và giải quyết được quản lý khóa: Không cần thỏa thuận khóa bí mật trước (nhược điểm của mật mã đối xứng), đồng thời khóa bí mật RSA chỉ dùng để bảo vệ khóa phiên. Đây chính là cách hệ EFS hoạt động: "Mã hóa bằng việc sử dụng mật mã khóa công khai (RSA, ECC) kết hợp mật mã đối xứng (DES-X, AES). Tập tin được mã hóa bằng mật mã đối xứng, sử dụng khóa ngẫu nhiên. Khóa mã hóa tập tin được mã hóa bằng khóa công khai."

- Xác thực server-client rõ ràng: Kết hợp chữ ký số RSA giúp máy khách chắc chắn đang kết nối với máy chủ thật, khắc phục hạn chế "không giải quyết triệt để xác thực hai chiều" khi chỉ dùng RSA.

- Tiết kiệm tài nguyên và dễ chịu tải: Máy chủ chỉ phải thực hiện phép toán RSA một lần cho mỗi phiên kết nối, còn phần lớn dữ liệu dùng mật mã đối xứng nên hệ thống chạy nhanh, chi phí CPU thấp, phù hợp với lưu lượng lớn của thương mại điện tử.

Bài 2 – Sai lầm trong phân phối khóa công khai

Một người dùng tải khóa công khai RSA của server từ một website không xác thực.

Sau đó, gửi dữ liệu mã hóa bằng khóa này. Nhưng dữ liệu bị giải mã bởi hacker.

Yêu cầu

1. Phân tích và giải thích rõ vì sao xảy ra sự cố trên.

2. Xác định loại tấn công, giải thích làm rõ loại tấn công đã xác định.

3. Đề xuất giải pháp phòng chống và giải thích tại sao cần áp dụng các giải pháp

này.

1. *Phân tích và giải thích rõ nguyên nhân xảy ra sự cố*

Sự cố xảy ra vì người dùng đã tải khóa công khai từ một trang web không được xác thực.

Trong hệ mật mã RSA, khóa công khai được dùng để mã hóa dữ liệu. Người dùng nghĩ rằng khóa nhận được là của máy chủ thật, nên dùng nó để mã hóa thông tin thanh toán. Tuy nhiên:

- Hacker đã can thiệp vào quá trình tải khóa (giữa người dùng và trang web).

- Hacker thay thế bằng một khóa công khai giả mà hacker tự tạo ra (hacker giữ khóa bí mật tương ứng).

- Người dùng vô tình dùng khóa giả này để mã hóa.

- Hacker dễ dàng dùng khóa bí mật của mình để giải mã và lấy được toàn bộ thông tin thanh toán.

Nguyên nhân gốc rễ là quá trình phân phối khóa công khai không an toàn. Không có cơ chế nào để người dùng kiểm tra xem khóa nhận được có thực sự thuộc về máy chủ hay không. Chỉ cần một lần tải sai, toàn bộ bảo mật của RSA bị phá vỡ mà không cần hacker phải bẻ khóa toán học.

2. *Xác định loại tấn công và giải thích rõ loại tấn công*

Đây là tấn công kiểu Man-in-the-Middle, cụ thể là thay thế khóa công khai.

Đặc điểm của loại tấn công này:

- Hacker không cần phá vỡ toán học của RSA (không cần phân tích thừa số lớn).

- Hacker chỉ can thiệp vào bước tải khóa công khai, thay bằng khóa giả của mình.

- Tấn công xảy ra rất dễ dàng nếu trang web dùng kết nối không mã hóa hoặc không kiểm tra chứng chỉ.

- Hacker có thể đọc được toàn bộ dữ liệu mà người dùng gửi mà không để lại dấu vết rõ ràng.

Loại tấn công này khác với các tấn công bẻ khóa RSA thông thường (dựa vào toán học). Nó khai thác lỗ hổng ở quy trình phân phối khóa, không phải ở bản thân thuật toán RSA.

3. *Đề xuất giải pháp phòng chống và giải thích tại sao cần áp dụng*

*Các giải pháp phòng chống cần áp dụng theo thứ tự ưu tiên:

- Sử dụng chứng chỉ kỹ thuật số được cấp bởi tổ chức uy tín: Máy chủ phải có chứng chỉ kỹ thuật số (X.509) được ký bởi một tổ chức cấp chứng chỉ tin cậy. Người dùng sẽ kiểm tra chứng chỉ này trước khi dùng khóa công khai.

- Bắt buộc dùng giao thức bảo mật truyền tải (HTTPS): Toàn bộ trang web phải chuyển hướng sang kết nối mã hóa, đồng thời kích hoạt cơ chế bảo vệ nghiêm ngặt (HSTS).

- Kiểm tra cố định chứng chỉ: Máy khách (trình duyệt hoặc ứng dụng) được lập trình để chỉ chấp nhận chứng chỉ cụ thể của máy chủ, ngăn chặn việc thay thế.

*Tại sao cần áp dụng các giải pháp này?

- Không có cách nào khác để người dùng biết chắc chắn khóa công khai nhận được là thật hay giả. Nếu không kiểm tra nguồn gốc, RSA dù mạnh đến đâu cũng trở nên vô dụng.

- Các giải pháp này ngăn chặn triệt để tấn công Man-in-the-Middle (thay thế khóa công khai) ngay từ bước tải khóa.

- Đây là yêu cầu bắt buộc theo các tiêu chuẩn bảo mật quốc tế cho hệ thống xử lý thông tin thanh toán (như tiêu chuẩn bảo mật dữ liệu thẻ thanh toán).

- Nếu không áp dụng, hệ thống sẽ dễ bị lừa đảo, mất lòng tin của khách hàng, thậm chí dẫn đến tổn thất tài chính lớn.

- Các giải pháp này đã được chứng minh hiệu quả qua thực tế và được tất cả các sàn thương mại điện tử lớn áp dụng.